

IAM Security Rules

Hospital File Management System

Identity & Access Management Policy Documentation

April 2026 · Confidential

This document catalogues every Identity and Access Management (IAM) control implemented in the Hospital File Management System. Controls that map directly to HIPAA Security Rule provisions are annotated with their CFR citation. Controls that derive from general IAM best practice or the course risk matrix are listed without a HIPAA reference.

1. Role-Based Access Control (RBAC)

HIPAA §164.312(a)(1)	Access control — Implement technical policies restricting access to ePHI to authorised users only.
HIPAA §164.312(a)(2)(i)	Unique user identification — Assign a unique name and/or number for identifying and tracking user identity.

Five roles are defined, each with a distinct permission set per file:

```
PERMISSIONS = {
  'supervisor': ['---', '---', '---', '---'],
  'admin': ['rwx', 'rwx', 'rwx', 'rw-'],
  'doctor': ['rwx', 'rw-', 'rw-', '---'],
  'nurse': ['r--', 'r--', 'r--', '---'],
  'patient': ['r--', '---', 'r--', '---'],
}
```

Every file operation passes through `can(role, file_index, action)`, which checks the matrix before allowing read / write / delete.

Rule / Control	Implementation in Code	HIPAA Ref.
Unique role per user	<code>role</code> field stored in <code>users.json</code>	§164.312(a)(2)(i)
Per-file R/W/X permissions	<code>PERMISSIONS</code> matrix + <code>can()</code> enforcer	§164.312(a)(1)
Role displayed in UI badge	<code>current_role</code> shown in header at all times	§164.312(a)(1)
Role change logged	<code>log_event('ROLE_CHANGE', ...)</code>	§164.312(b)

2. Authentication — Password + MFA (TOTP)

HIPAA §164.312(d)	Person or entity authentication — Implement procedures to verify that a person seeking access is the one claimed.
HIPAA §164.312(a)(2)(i)	Unique user identification — Each account has a unique username and individual credential.

Password hashing — PBKDF2-HMAC-SHA256 + 128-bit salt

```
def hash_pw(pw, salt=None):
    if salt is None: salt = secrets.token_hex(16)
    dk = hashlib.pbkdf2_hmac('sha256', pw.encode(), salt.encode(), 260_000)
    return f'{salt}${dk.hex()}'
```

260,000 PBKDF2 iterations exceed NIST SP 800-132 recommendations. Legacy bare-SHA256 hashes are transparently migrated on next login.

Password complexity policy

```
PASSWORD_MIN_LEN = 8 | REQUIRE_UPPER = True | REQUIRE_DIGIT = True | REQUIRE_SPECIAL = True
```

Time-based One-Time Password (TOTP / RFC 6238)

TOTP is generated via HMAC-SHA1 over a 30-second counter. A ±1 window tolerates clock skew. Every new user receives a unique Base-32 secret and must activate 2FA on first login via QR-code or manual key entry.

Rule / Control	Implementation in Code	HIPAA Ref.
Unique username per account	users.json key uniqueness enforced at creation	§164.312(a)(2)(i)
PBKDF2-HMAC-SHA256 hashing	hash_pw() – 260,000 iterations + 128-bit salt	§164.312(d)
Password complexity	validate_password() – length, upper, digit, symbol	§164.312(d)
TOTP 2FA (RFC 6238)	totp_code() / verify_totp() – 30-second window	§164.312(d)
2FA activation on first login	_show_totp_activate() forced before dashboard	§164.312(d)
QR-code provisioning	totp_uri() → qrcode rendered in-app	—

3. Attribute-Based Access Control (ABAC)

HIPAA §164.312(a)(1)	Access control — Technical policies restricting ePHI access; context-aware controls supported.
HIPAA §164.310(b)	Workstation use — Policies governing proper functions performed on workstations with ePHI access.

ABAC Rule 1 — Time Policy (working hours gate)

```
WORK_HOUR_START = 8 # 08:00
WORK_HOUR_END = 18 # 18:00
TIME_EXEMPT_ROLES = {'admin', 'supervisor'}
```

Non-privileged roles (doctor, nurse, patient) are blocked outside 08:00–18:00. A live countdown timer shows seconds until re-opening. Admins and supervisors may bypass with credentials + 2FA.

ABAC Rule 2 — Network / Location Policy

```
HOSPITAL_ALLOWED_PREFIXES = ['127.', '192.168.1.', '192.168.0.', '10.0.', '10.10.', '172.16.']
```

The detected IP is matched against allowed hospital subnets. Any connection from an external or unknown network is blocked unconditionally before credentials are even requested.

Rule / Control	Implementation in Code	HIPAA Ref.
Time-based access gate	<code>check_time_policy()</code> – enforced at login screen	§164.310(b)
Network / IP allowlist	<code>check_network_policy()</code> – CIDR prefix matching	§164.312(a)(1)
Privileged bypass for admins	<code>PRIVILEGED_LOGIN</code> event + re-authentication required	§164.312(a)(1)
Real-time countdown on block	<code>Tkinter after()</code> loop updates HH:MM:SS display	—

4. Account Lifecycle Management

HIPAA §164.308(a)(3)(ii)(C)	Termination procedures — Implement procedures for terminating access when employment ends or access no longer required.
HIPAA §164.308(a)(3)(i)	Workforce access management — Implement policies for authorising access to ePHI.

The User Manager panel exposes four lifecycle operations on any account:

- **Force Logout** — immediately invalidates the current session token and logs the event.
- **Timed Suspension** — sets `suspended=True` + `suspended_until` timestamp; auto-expires.
- **Manual Suspension** — indefinite block requiring explicit admin reactivation.
- **Reactivate** — clears suspension flags and logs the reinstatement.

A session watchdog polls every 3 seconds; if the current user's account is suspended mid-session (by another admin), an automatic force-logout fires immediately — no manual intervention required.

Rule / Control	Implementation in Code	HIPAA Ref.
Timed account suspension	<code>suspended_until</code> ISO timestamp in <code>users.json</code>	§164.308(a)(3)(ii)(C)
Manual suspension	<code>suspended=True</code> ; cleared only by explicit reactivation	§164.308(a)(3)(ii)(C)
Force logout	<code>log_event('FORCE_LOGOUT')</code> + session cleared	§164.308(a)(3)(ii)(C)
Session watchdog	<code>_start_session_watchdog()</code> – polls every 3 s	§164.308(a)(3)(i)
Role assignment at creation	<code>role</code> field set during user creation workflow	§164.308(a)(3)(i)
Supervisor creation control	Only supervisors can create other supervisors	—

5. Session & Inactivity Management

HIPAA
§164.312(a)(2)(iii)

Automatic logoff — Implement electronic procedures that terminate an electronic session after a period of inactivity.

```
SESSION_TIMEOUT_SEC = 1800 # 30 minutes of inactivity → automatic logout
```

Any user interaction resets the inactivity timer. On expiry a modal dialog informs the user and the session is cleared. The event is written to the audit log with the triggering username and timeout value.

Rule / Control	Implementation in Code	HIPAA Ref.
30-minute inactivity timeout	<code>SESSION_TIMEOUT_SEC=1800; after() timer reset on each action</code>	§164.312(a)(2)(iii)
Session expiry audit entry	<code>log_event('SESSION_EXPIRED', username, ...)</code>	§164.312(a)(2)(iii)
Logout clears all timers	<code>_cancel_session_timer() + _cancel_session_watchdog()</code>	—

6. Brute-Force Protection — Account Lockout

HIPAA
§164.312(a)(2)(i)

Unique user identification — Procedures to detect and limit repeated failed authentication attempts.

```
MAX_LOGIN_ATTEMPTS = 5 # consecutive failures trigger lockout
LOCKOUT_SECONDS = 300 # 5-minute lockout window
```

Failed timestamps are stored in a rolling in-memory window. Once 5 failures occur within 300 seconds the account is locked and a countdown is displayed. The counter resets automatically after the window expires or on successful login.

Rule / Control	Implementation in Code	HIPAA Ref.
Max 5 failed attempts	<code>record_failed_attempt() – sliding 300-second window</code>	§164.312(a)(2)(i)
5-minute lockout	<code>is_account_locked() returns remaining seconds</code>	§164.312(a)(2)(i)
Lockout cleared on login	<code>clear_failed_attempts() on successful authentication</code>	—
Failure logged every time	<code>log_event('LOGIN_FAIL', username, reason=...)</code>	§164.312(b)

7. Audit Logging & Activity Monitoring

HIPAA §164.312(b)

Audit controls — Hardware, software, and procedural mechanisms to record and examine activity in systems containing ePHI.

```
def log_event(event_type, username, detail=''):
    ts = datetime.now().strftime('%Y-%m-%d %H:%M:%S')
    with open(LOGS_FILE, 'a') as f:
        f.write(f'[{ts}] [{event_type:<20}] user={username:<20} {detail}')
```

Events captured include:

- LOGIN_SUCCESS / LOGIN_FAIL

- ACCESS_DENIED (time + network)
- PRIVILEGED_LOGIN / LOGOUT / SESSION_EXPIRED
- READ / WRITE on every file operation
- USER_CREATED / ADMIN_CREATED / SUPERVISOR_CREATED
- ROLE_CHANGE / SUSPEND_TIMED / SUSPEND_MANUAL / REACTIVATE
- FORCE_LOGOUT / EXPORT_LOGS / LOGS_CLEARED

The System Logs screen provides real-time filtering by user, event type, IP, date, time range, and role. Logs can be exported to CSV or JSON for external analysis. Only supervisors may clear the audit trail, and even that action is itself logged before deletion.

Rule / Control	Implementation in Code	HIPAA Ref.
Tamper-evident append-only log	<code>open(LOGS_FILE, 'a') – append mode only</code>	§164.312(b)
Timestamped entries	<code>datetime.now()</code> ISO format on every record	§164.312(b)
IP address in login events	<code>ip=</code> field added to LOGIN_SUCCESS + PRIVILEGED_LOGIN	§164.312(b)
File R/W audit trail	<code>log_event('READ'/'WRITE', user, file=...)</code>	§164.312(b)
CSV / JSON export	<code>export_csv()</code> / <code>export_json()</code> in log viewer toolbar	§164.312(b)
Supervisor-only log clear	<code>role check before open(LOGS_FILE, 'w').close()</code>	—

8. Additional Controls (IAM Best Practice)

The following controls are implemented as general IAM best practice and align with the course risk matrix. They do not map to a single specific HIPAA CFR citation but support overall HIPAA compliance posture.

Control	Implementation Note
Legacy hash migration	<code>verify_pw()</code> detects bare-SHA256 and migrates transparently on next login
QR-code TOTP provisioning	<code>totp_uri()</code> + qrcode library renders scannable QR in-app
Split-screen demo mode	<code>--split</code> flag launches two independent panels sharing the same database
Live log monitor (Supervisor)	<code>_show_live_monitor()</code> auto-refreshes every 2 s; supervisor-only view
Horizontal scroll in narrow panels	Canvas+Scrollbar pattern applied to User Manager and Log toolbar
Password confirmation field	create user / bootstrap flows require password typed twice
TOTP attempt limiting	<code>_totp_attempts</code> counter; excessive failures trigger re-login
Bootstrap admin creation	First-run wizard forces creation of initial admin + 2FA before any access

HIPAA references: 45 CFR Part 164 — Security and Privacy Rules. All section numbers refer to the HIPAA Security Rule (45 CFR §164.300–§164.318). This document reflects the state of the codebase as of April 2026.